

Zero-Trust Architecture & Design Trade-Offs

Zero-Trust Secure Backend & Identity Threat Detection · Technical Documentation

Architectural Design & Security Engineering Trade-Offs

1. System Architecture Overview

The **Zero-Trust Secure Evidence Exchange & Identity Threat Detection System** is designed from first principles around defense-in-depth, zero-trust access verification, and empirical adversarial validation.

`mermaid flowchart TD subgraph ClientLayer [Client & Identity Layer] A[User Browser / Forensic Client] -->|FIDO2 / WebAuthn Ceremony| B(WebAuthn RP) A -->|OIDC Fallback| C(Authlib OIDC) B --> D[Token Service] C --> D D -->|Short-lived Access JWT 15m| E[API Gateway] D -->|Rotating Refresh Token Family| F[(Token Family Store)] end

```
subgraph DefenseMiddleware [Security & Telemetry Middleware]
  E --> G[Telemetry Extractor]
  G -->|Engineered Vector| H[IsolationForest Anomaly Detector]
  E --> I[AuthZ Enforcement Engine]
end

subgraph AuthZLayer [Fail-Secure Policy Engine]
  I -->|REST Query POST /v1/data/case_access| J{OPA Sidecar}
  J -->|200 OK + Decision| I
  J -->|Timeout / 500 / Network Error| K[FAIL-SECURE: Unconditional DENY]
  K --> I
end

subgraph DataProtection [Envelope Encryption & Storage]
  I -->|Allowed Action| L[Crypto Engine]
  L -->|Wrap/Unwrap DEK| M[HashiCorp Vault Transit]
  L -->|Field-Level AES-GCM| N[PII Cipher Engine]
  L --> O[(PostgreSQL Database)]
  I -->|Audit Event Log| P[(Append-Only Audit Log)]
end
```

2. Deep-Dive Architectural Trade-Offs

2.1 Why WebAuthn / Passkeys-First Primary Authentication?

- **Phishing Resistance:** Traditional passwords, SMS OTPs, and even TOTP authenticators are vulnerable to reverse-proxy adversary-in-the-middle (AiTM) phishing frameworks (e.g. Evilginx). WebAuthn couples public-key cryptography to the TLS origin (WEBAUTHN_ORIGIN), cryptographically binding the authentication assertion to the specific domain.

- **Hardware-Bound Identity:** Private keys never leave the secure enclave or TPM of the client device. The backend stores only public keys and monotonic signature counters (webauthn_sign_count) to detect cloned authenticators.
 - **Fallback Balance:** OIDC federated fallback via Authlib supports enterprise IdP federation while maintaining short-lived tokens and token family lineage.
-

2.2 Why Open Policy Agent (OPA) Over Hand-Rolled Application Logic?

- **Policy-as-Code vs Code-Smell:** Hardcoded if user.role == ... checks spread across API route handlers quickly degrade, leading to Broken Object Level Authorization (BOLA/IDOR) vulnerabilities. OPA decouples authorization rules into declarative Rego policies (policies/case_access.rego).
 - **Unified RBAC + ABAC:** Combines coarse role-based permissions with fine-grained attribute checks (e.g. user.id == case.assigned_analyst_id and classification clearance TLP:RED).
 - **Fail-Secure Architecture:** The OPA client (src/authz/client.py) is engineered so that if the sidecar crashes, encounters network partition, or times out, the authorization decision defaults unconditionally to **DENY**.
-

2.3 Why HashiCorp Vault Transit Envelope Encryption?

- **Key Segregation:** Encrypting large database tables with a single static symmetric key creates catastrophic single points of failure.
 - **Envelope Protocol:**
 - A unique 256-bit AES-GCM Data Encryption Key (DEK) is generated per case file.
 - The payload is encrypted with the DEK.
 - The DEK is wrapped (encrypted) by Vault's Key Encryption Key (KEK).
 - Only the wrapped DEK and ciphertext are stored in PostgreSQL.
 - **Field-Level Isolation:** Sensitive subject PII is encrypted individually (FieldCrypto), allowing unencrypted metadata (title, classification, created_at) to remain indexed and queryable without leaking identities.
-

2.4 Why Precision & Contamination Matter in SecOps Anomaly Detection

- **Alert Fatigue Prevention:** In a Security Operations Center (SecOps), a high False Positive Rate (FPR) overwhelms analysts. Setting the IsolationForest contamination rate at 0.04 aligns with expected anomaly frequency, keeping benign false positive rate low (0.00%) while achieving high recall (1%) across all attack categories.
- **Multi-Dimensional Feature Space:** Rather than relying solely on raw request counts, the model combines velocity, Haversine travel velocity (> 1,500 km/h for impossible travel), device fingerprint drift, off-hours z-scores, and endpoint entropy.